

Cyber Threat Intelligence

Executive Briefing

Report Date: June 29, 2026

Generated: 2026-06-29 11:06 UTC | Classification: TLP:AMBER

Prepared by: Auto-CTI Autonomous Threat Intelligence Pipeline

1. Risk Statistics Summary

Critical	High	Medium	Low	Total
1	8	10	1	20

2. Executive Summary

As of June 29, 2026, the security operations center has concluded the analysis of 20 identified vulnerabilities, categorized as follows: 1 Critical, 8 High, 10 Medium, and 1 Low. The current organizational risk posture is assessed as 'High' due to the prevalence of path traversal and arbitrary file write exploits within our development infrastructure. The primary threat is CVE-2026-53519, 'Pre-auth Traversal and JWT Secret Exposure,' which represents the most significant risk to the enterprise as it facilitates unauthenticated access to sensitive authentication tokens. Given the nature of these findings, we recommend an immediate posture of 'Accelerated Remediation' to mitigate the risk of unauthorized system compromise. Executive leadership must authorize the immediate deployment of emergency patches and configuration hardening measures as outlined in the subsequent action items.

3. Critical Action List

- CVE-2026-53519: Isolate all Nezha Monitoring instances from public networks and apply patches within 4 hours.
- CVE-2026-55698: Audit and rotate all pnpm lockfile configurations to prevent arbitrary byte execution within 24 hours.
- CVE-2026-49340: Restrict Gonic playlist creation permissions and enforce strict file system input validation within 24 hours.
- CVE-2026-50015: Implement a mandatory review policy for all external pnpm patch files prior to application within 48 hours.
- CVE-2026-55700: Update all pnpm environments to the latest stable release to resolve path traversal risks within 48 hours.

4. Quick Reference: All Identified Vulnerabilities

CVE ID	Finding Name	CVSS	Severity	Urgency	CWE
--------	--------------	------	----------	---------	-----

CVE-2026-53519	Pre-auth Traversal and JWT Secret...	9.1	Critical	100/100	CWE-22
CVE-2026-55698	Lockfile Short-Circuit and Arbitr...	8.8	High	89/100	CWE-345
CVE-2026-49340	Arbitrary File Write in Gonic Pla...	8.1	High	83/100	CWE-22
CVE-2026-50015	Arbitrary File Write via Maliciou...	7.3	High	76/100	CWE-22
CVE-2026-55700	Arbitrary File Write via Path Tra...	7.1	High	74/100	CWE-22
CVE-2026-49338	Insecure Direct Object Reference ...	7.1	High	74/100	CWE-285
CVE-2026-49339	Path Traversal in Gonic Playlist ...	7.1	High	74/100	CWE-22
CVE-2026-53523	Host Header Injection in Nezha Mo...	6.8	Medium	71/100	CWE-601
CVE-2026-55699	Unauthorized Deletion of PNPM_HOM...	6.5	Medium	69/100	CWE-22
CVE-2026-55180	Environment Secret Exposure to Ma...	6.5	Medium	69/100	CWE-200
CVE-2026-53522	WebSocket Resource Exhaustion in ...	6.5	Medium	69/100	CWE-770
CVE-2026-55697	Remote Code Execution via Malicio...	7.5	High	68/100	CWE-78
CVE-2026-55487	Lifecycle Execution via Manifest ...	7.5	High	68/100	CWE-346
CVE-2026-53521	Unauthorized DDNS Profile Usage i...	6.4	Medium	68/100	CWE-863
CVE-2026-53465	Heap Buffer Over-Write in ImageMa...	6.2	Medium	66/100	CWE-122
CVE-2026-53520	Dashboard Host Preemption in Nezh...	6.5	Medium	59/100	CWE-284
CVE-2026-54243	CSV Formula Injection in Statamic...	6.1	Medium	55/100	CWE-1236
CVE-2026-53464	Memory Leak in ImageMagick Wand P...	4.0	Medium	46/100	CWE-401
CVE-2026-54242	SSRF in Statamic Glide Image Proc...	4.9	Medium	44/100	CWE-367
CVE-2026-54244	Unauthorized Content Submission i...	3.5	Low	27/100	CWE-863

5. Detailed Vulnerability Findings

CVE-2026-53519

Finding: Pre-auth Traversal and JWT Secret Exposure

CVSS v3.1 Score: 9.1 | Severity: Critical | Urgency Score: 100/100 | CWE: CWE-22

MITRE ATT&CK: T1083, T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

Nezha Monitoring contains a path traversal vulnerability in the /dashboard.. endpoint. This allows an unauthenticated user to leak the server's JWT secret key, potentially leading to full account takeover.

Proof of Concept (PoC):

An unauthenticated attacker sends a request to '/dashboard../config_file_path'. The server interprets the traversal

sequence and serves the content of the configuration file containing the JWT secret, which the attacker then uses to forge administrative sessions.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53519>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53519>

CVE-2026-55698

Finding: Lockfile Short-Circuit and Arbitrary Byte Execution in pnpm

CVSS v3.1 Score: 8.8 | Severity: High | Urgency Score: 89/100 | CWE: CWE-345

MITRE ATT&CK: T1195, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The pnpm environment lockfile mechanism can be coerced into skipping standard package resolution steps. This allows an attacker to force the execution of arbitrary bytes provided in a malicious lockfile, leading to potential remote code execution.

Proof of Concept (PoC):

The attacker contributes a modified lockfile to a repository. When a user runs pnpm install, the installer ignores verified package sources and executes the attacker-defined payload embedded in the lockfile structure, granting immediate code execution.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55698>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55698>

CVE-2026-49340

Finding: Arbitrary File Write in Gonic Playlist Creation

CVSS v3.1 Score: 8.1 | Severity: High | Urgency Score: 83/100 | CWE: CWE-22

MITRE ATT&CK: T1059, T1083

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:H

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

Gonic is susceptible to an arbitrary file write vulnerability during playlist creation. An authenticated user can craft M3U content and write it to an attacker-specified path on the underlying host filesystem.

Proof of Concept (PoC):

The attacker sends a crafted playlist creation request where the playlist name includes directory traversal characters.

The server saves the M3U content into a location specified by the attacker, allowing for potential overwriting of critical configuration files.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49340>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49340>

CVE-2026-50015

Finding: Arbitrary File Write via Malicious pnpm Patch

CVSS v3.1 Score: 7.3 | Severity: High | Urgency Score: 76/100 | CWE: CWE-22

MITRE ATT&CK: T1485, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	Low

Description:

pnpm is vulnerable to path traversal within patch files. An attacker can craft a malicious patch that, when applied, writes or deletes files outside the intended project directory, compromising the host filesystem.

Proof of Concept (PoC):

A user applies a project patch from an untrusted source. The patch contains traversal sequences in the file path section. Upon application, pnpm writes the patched content to a location outside the directory, potentially overwriting system files.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50015>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50015>

CVE-2026-55700

Finding: Arbitrary File Write via Path Traversal in pnpm

CVSS v3.1 Score: 7.1 | Severity: High | Urgency Score: 74/100 | CWE: CWE-22

MITRE ATT&CK: T1059, T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:H/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	None
Availability Impact	Low

Description:

The pnpm package manager contains a path traversal vulnerability during the 'stage download' process. By manipulating the manifest name or version string, an attacker can force the application to write files outside of the intended destination directory, potentially overwriting sensitive system files.

Proof of Concept (PoC):

An attacker creates a malicious package with a specially crafted version string containing path traversal characters.

When a victim installs this dependency, pnpm interprets the malicious path and writes package components into unauthorized directories, such as the startup folder or configuration paths.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55700>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55700>

CVE-2026-49338

Finding: Insecure Direct Object Reference in Subsonic API

CVSS v3.1 Score: 7.1 | Severity: High | Urgency Score: 74/100 | CWE: CWE-285

MITRE ATT&CK: T1531, T1040

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network	Attack Complexity	Low
Privileges Required	Low	User Interaction	None
Scope	Unchanged	Confidentiality Impact	High
Integrity Impact	High	Availability Impact	None

Description:

The Subsonic API fails to enforce proper authorization checks when users access playlists. An authenticated user can read or delete the playlists of other users by manipulating the playlist ID in API requests.

Proof of Concept (PoC):

An authenticated user intercepts an API call used to fetch playlist details. By incrementing or changing the playlist ID parameter to match another user's content, the server returns the requested private playlist information without validating ownership.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49338>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49338>

CVE-2026-49339

Finding: Path Traversal in Gonic Playlist Access

CVSS v3.1 Score: 7.1 | Severity: High | Urgency Score: 74/100 | CWE: CWE-22

MITRE ATT&CK: T1083, T1565

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network	Attack Complexity	Low
Privileges Required	Low	User Interaction	None
Scope	Unchanged	Confidentiality Impact	High
Integrity Impact	High	Availability Impact	None

Description:

The Gonic music server implementation contains a path traversal vulnerability in the playlist ID handler. This bypasses ownership checks, allowing unauthorized users to read or delete arbitrary playlists stored within the host filesystem.

Proof of Concept (PoC):

An authenticated user submits a request to the playlist endpoint with an ID parameter containing traversal sequences like '..../'. The server resolves the path and grants access to files outside the intended playlist directory, enabling

unauthorized deletion or disclosure.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49339>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49339>

CVE-2026-53523

Finding: Host Header Injection in Nezha Monitoring

CVSS v3.1 Score: 6.8 | Severity: Medium | Urgency Score: 71/100 | CWE: CWE-601

MITRE ATT&CK: T1566, T1210

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Changed
Integrity Impact	Low

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	Low
Availability Impact	None

Description:

Nezha Monitoring contains an OAuth2 redirect vulnerability due to improper handling of the Host header. This allows for open redirection, which an attacker can use for phishing campaigns.

Proof of Concept (PoC):

The attacker crafts a malicious link that includes a fake Host header pointing to a domain they control. When the victim clicks the link, the server redirects them to the attacker's site, facilitating credential harvesting.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53523>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53523>

CVE-2026-55699

Finding: Unauthorized Deletion of PNPM_HOME Directory

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 69/100 | CWE: CWE-22

MITRE ATT&CK: T1485, T1562

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Local
Privileges Required	Low
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

A flaw exists in pnpm where a reserved binary name triggers an improper deletion routine during a global removal operation. This can lead to the unintended removal of the PNPM_HOME directory, resulting in a denial of service for the package management environment.

Proof of Concept (PoC):

A local attacker invokes a global remove command targeting a specific malicious binary name. The package manager fails to sanitize the path, executing a recursive delete command on the parent PNPM_HOME directory instead of the specific package binary.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55699>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55699>

CVE-2026-55180

Finding: Environment Secret Exposure to Malicious Registry

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 69/100 | CWE: CWE-200

MITRE ATT&CK: T1552, T1040

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

pnpm's configuration handling allows for the expansion of sensitive environment variables into registry request headers. A malicious repository or proxy can trick the system into leaking these secrets before scripts are even executed.

Proof of Concept (PoC):

A user connects to a malicious registry server. The registry returns a specific configuration that triggers pnpm to include sensitive environment variables (such as tokens or credentials) in the headers of outgoing requests back to the registry.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55180>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55180>

CVE-2026-53522

Finding: WebSocket Resource Exhaustion in Nezha Monitoring

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 69/100 | CWE: CWE-770

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

Nezha Monitoring fails to limit the number of open WebSocket streams. An attacker can initiate numerous connections to exhaust system resources, leading to a Denial of Service.

Proof of Concept (PoC):

The attacker runs a script that spawns thousands of WebSocket connections to the monitoring dashboard. The server consumes all available memory or file descriptors, causing legitimate users to be unable to access the dashboard.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53522>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53522>

CVE-2026-55697

Finding: Remote Code Execution via Malicious Pacquet Engine

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-78

MITRE ATT&CK: T1195, T1203

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	High
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

pnpm allows repository-controlled configurations to select a native install engine through the paquet library. This can be abused by a malicious package registry to force the execution of arbitrary commands on the victim's host during installation.

Proof of Concept (PoC):

A user installs a package from a compromised or malicious registry. The registry injects configuration directives that cause pnpm to switch to a malicious native install engine, which subsequently executes unauthorized shell commands on the developer's system.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55697>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55697>

CVE-2026-55487

Finding: Lifecycle Execution via Manifest Identity Spoofing

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-346

MITRE ATT&CK: T1557, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

pnpm fails to correctly validate manifest identities, allowing an attacker to spoof package metadata. This satisfies security checks for allowed builds and causes the package manager to execute malicious lifecycle scripts provided by the attacker.

Proof of Concept (PoC):

The attacker publishes a package with a forged manifest that masquerades as a trusted source. When a victim installs the package, the pnpm installer bypasses integrity checks and executes the attacker's script payload under the victim's privileges.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55487>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55487>

CVE-2026-53521

Finding: Unauthorized DDNS Profile Usage in Nezha

CVSS v3.1 Score: 6.4 | Severity: Medium | Urgency Score: 68/100 | CWE: CWE-863

MITRE ATT&CK: T1078

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:L

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	Low

Description:

Nezha Monitoring allows users to reference future DDNS profile IDs. This leads to an authorization bypass where a user can perform actions in the context of another user's DDNS profile.

Proof of Concept (PoC):

An attacker creates a DDNS profile request using a predicted future profile ID. The system validates the request incorrectly, allowing the attacker to link or manipulate another user's existing DDNS profile.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53521>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53521>

CVE-2026-53465

Finding: Heap Buffer Over-Write in ImageMagick

CVSS v3.1 Score: 6.2 | Severity: Medium | Urgency Score: 66/100 | CWE: CWE-122

MITRE ATT&CK: T1203, T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:L/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	High
User Interaction	Required
Confidentiality Impact	Low
Availability Impact	High

Description:

A heap buffer overflow vulnerability exists in the ImageMagick SF3 encoder. Processing a multi-frame image with specific parameters can lead to a heap-based buffer over-write, potentially causing crashes or remote code execution.

Proof of Concept (PoC):

An attacker uploads a specially crafted multi-frame SF3 image file to a service that utilizes ImageMagick. When the server attempts to process or convert the file, the heap overflow triggers, potentially allowing the execution of arbitrary code.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53465>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53465>

CVE-2026-53520

Finding: Dashboard Host Preemption in Nezha Monitoring**CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 59/100 | CWE: CWE-284**

MITRE ATT&CK: T1078, T1562

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:H/A:L

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	Low

Description:

Authenticated users in Nezha Monitoring can claim a dashboard Host even through NAT. This enables an attacker to preempt and take control of all dashboard routing for a targeted instance.

Proof of Concept (PoC):

An attacker registers a host name already in use by another dashboard. Due to weak claim validation, the server accepts the registration, rerouting all traffic to the attacker's controlled agent.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53520>Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53520>**CVE-2026-54243****Finding: CSV Formula Injection in Statamic Exports****CVSS v3.1 Score: 6.1 | Severity: Medium | Urgency Score: 55/100 | CWE: CWE-1236**

MITRE ATT&CK: T1566, T1059

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:C/C:L/I:L/A:L

Attack Vector	Network
Privileges Required	Low
Scope	Changed
Integrity Impact	Low

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	Low
Availability Impact	Low

Description:

Statamic is vulnerable to CSV formula injection. When administrative users export form submissions to a CSV file, malicious formulas can be embedded in the content, leading to code execution if the file is opened in spreadsheet software.

Proof of Concept (PoC):

An attacker submits a form containing a string beginning with an '=' formula character. When an administrator downloads the export report and opens it in Excel, the software interprets the injected content as a command, potentially executing malicious system commands.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-54243>Ref: <https://www.cve.org/CVERecord?id=CVE-2026-54243>**CVE-2026-53464****Finding: Memory Leak in ImageMagick Wand Parser**

CVSS v3.1 Score: 4.0 | Severity: Medium | Urgency Score: 46/100 | CWE: CWE-401

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	Low

Description:

The ImageMagick wand option parser suffers from a memory leak when processing malformed or invalid arguments. Attackers can exploit this to consume excessive system memory, potentially leading to resource exhaustion.

Proof of Concept (PoC):

An attacker repeatedly sends requests with malicious arguments to a service using the ImageMagick wand API. Each request leaks memory, eventually resulting in an out-of-memory state that crashes the service process.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-53464>Ref: <https://www.cve.org/CVERecord?id=CVE-2026-53464>**CVE-2026-54242****Finding: SSRF in Statamic Glide Image Processor****CVSS v3.1 Score: 4.9 | Severity: Medium | Urgency Score: 44/100 | CWE: CWE-367**

MITRE ATT&CK: T1040, T1082

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	High
User Interaction	None
Confidentiality Impact	Low
Availability Impact	None

Description:

Statamic's Glide image processor is susceptible to Server-Side Request Forgery due to DNS rebinding. This allows an attacker to cause the server to make requests to internal network resources.

Proof of Concept (PoC):

An attacker creates a malicious URL pointing to a domain that performs DNS rebinding. They submit this URL to the Glide image processor, which then attempts to fetch the resource, enabling the attacker to scan or probe internal network services.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-54242>Ref: <https://www.cve.org/CVERecord?id=CVE-2026-54242>**CVE-2026-54244****Finding: Unauthorized Content Submission in Statamic****CVSS v3.1 Score: 3.5 | Severity: Low | Urgency Score: 27/100 | CWE: CWE-863**

MITRE ATT&CK: T1068, T1078

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	None

Description:

Statamic CMS has a flaw in its authorization logic where users with read-only access can submit Live Preview content. This content is intended to be restricted to editors, allowing unauthorized content creation.

Proof of Concept (PoC):

A low-privileged user authenticates and accesses the preview submission endpoint. The system incorrectly validates the permissions for this specific action, allowing the user to create or manipulate Live Preview content they should not have access to.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-54244>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-54244>

6. Methodology & Data Sources

This report was generated by the Auto-CTI Autonomous Cyber Threat Intelligence Pipeline, an automated multi-agent system designed to simulate a real-world Security Operations Center (SOC) workflow. The pipeline operates in three sequential stages: (1) the Scout Agent collects the latest CVE disclosures from the GitHub Advisory Database and cross-references active threat pulses via AlienVault OTX; (2) the Triage Agent performs structured analysis using the CVSS v3.1 scoring standard, assigns CWE root-cause classifications, maps each vulnerability to relevant MITRE ATT&CK techniques, and computes a composite Urgency Score; (3) the Publisher Agent synthesizes the triaged data into this executive briefing. All CVE identifiers, CVSS scores, and CWE mappings are sourced directly from official databases and are verifiable via the references provided in Section 5. Severity classification follows the CVSS v3.1 standard: Critical (9.0-10.0), High (7.0-8.9), Medium (4.0-6.9), Low (0.1-3.9).

Primary Data Sources:

- GitHub Advisory Database -- <https://github.com/advisories>
- NIST National Vulnerability Database (NVD) -- <https://nvd.nist.gov/>
- AlienVault Open Threat Exchange (OTX) -- <https://otx.alienvault.com/>
- MITRE ATT&CK Framework -- <https://attack.mitre.org/>
- CVSS v3.1 Specification -- <https://www.first.org/cvss/v3.1/specification-document>
- Common Weakness Enumeration (CWE) -- <https://cwe.mitre.org/>
- CVE Program -- <https://www.cve.org/>